

Vulnerability Assessment Report:

Executive Summary: A vulnerability assessment was conducted on a fictional Flipkart-style e-commerce application to evaluate its overall security posture. The assessment identified two high-risk vulnerabilities that could expose sensitive customer data and impact business operations if left unaddressed. While the application demonstrates core functionality, improvements in secure coding and access control are necessary. Prompt remediation of the identified issues will reduce security risks, strengthen customer trust, and improve the application's overall resilience.

Findings:

1. SQL Injection (SQLi)

Risk Rating: High

Description:

- User input is not properly validated before being used in database queries.
- An attacker may manipulate SQL queries to access, modify, or delete sensitive data.

Request:

GET /search?q='

Response:

500 Internal Server Error

Database Error:

SQL syntax error near ""

2. Insecure Direct Object Reference (IDOR)

Risk Rating: High

Description:

- The application allows access to resources by changing object identifiers without verifying user authorization.
- An attacker could potentially view another customer's order information.

Original Request:

GET /orders/10245

Modified Request:

GET /orders/10246

Response:

- Order Details:
- Customer: Jane Smith
- Order Status: Delivered
- Shipping Address: [Redacted]

Recommendations:

1. SQL Injection
 - Use parameterized queries (prepared statements) instead of dynamic SQL.
 - Validate and sanitize all user inputs.
 - Apply the principle of least privilege for database accounts.
 - Prevent detailed database errors from being displayed to users.
2. Insecure Direct Object Reference (IDOR)
 - Perform server-side authorization checks for every request.
 - Verify that users can only access their own resources.
 - Use indirect or unpredictable object identifiers where appropriate.
 - Conduct regular access control testing to identify authorization issues.

Overall Risk Assessment:

- Overall Risk Level: Moderate
- High-Risk Findings: 2
- Recommended Priority: Address both vulnerabilities as soon as possible to reduce the risk of unauthorized access and data exposure.